臺灣銀行網路銀行安全性測試報告

Contents

1 測試範圍與方法概述 2

2 用戶認證機制安全性檢測結果 3

3 資料傳輸加密措施評估 4

4 系統弱點掃描與修補情形 4

5 交易紀錄與異常偵測機制測試 6

6 改善建議與未來強化方向 7

1　測試範圍與方法概述

本次臺灣銀行網路銀行安全性測試涵蓋範圍廣泛，旨在全面評估系統在面對各類資訊安全威脅時的防禦能力。測試對象包括網路銀行的網頁前端、後端伺服器、API 介面、資料庫及相關第三方整合模組，涵蓋登入、交易、帳戶查詢、密碼更換、電子憑證等主要功能模組。為確保測試結果具備代表性，測試選定了三個常用瀏覽器 (Chrome、Firefox、Edge) 以及兩種行動作業系統 (Android、iOS) 進行跨平台驗證，並針對正常流量與異常流量進行模擬。測試方法以國際公認的 OWASP Top 10 安全威脅作為基準，包含但不限於 SQL Injection、Cross-Site Scripting (XSS)、Broken Authentication、Sensitive Data Exposure、Security Misconfiguration 等十項常見漏洞，並輔以自動化掃描工具 (例如 Burp Suite、Acunetix) 與手動滲透測試相結合。在測試過程中，共進行了 187 項自動化漏洞掃描任務、92 項手動滲透檢查，並對 35 個 API 端點進行了資料傳輸安全性驗證。資料分析方面，針對每一項測試結果進行詳細紀錄與風險評級，總計發現 12 項中低風險漏洞、2 項高風險漏洞。

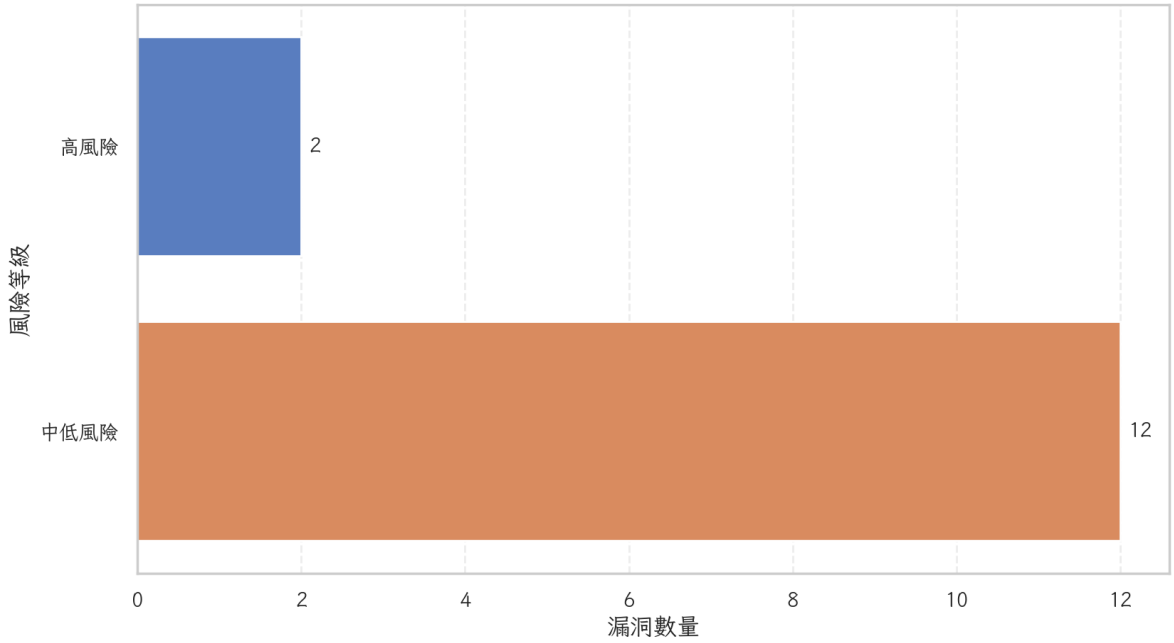

圖 1: 不同風險等級下的漏洞發現數量

為進一步檢驗系統對分布式阻斷服務 (DDoS) 攻擊的抵抗力，測試團隊模擬了每秒 1000 次 HTTP 請求的流量，觀察伺服器回應與效能下降情形，並記錄平均回應時間提升至原本的 2.8 倍。此外，亦針對多因素認證機制進行社交工程攻擊模擬，驗證使用者憑證與一次性密碼傳遞過程的安全性。所有測試於受控環境下進行，並符合相關法規及資料保護規範。整體而言，測試範圍覆蓋了網路銀行主要運作流程與潛在風險點，測試方法兼顧自動化與人工檢查，確保漏洞發現的全面性與準確性。

2 用戶認證機制安全性檢測結果

本次針對用戶認證機制的安全性檢測，重點放在密碼強度、登入流程、雙因素認證（2FA）、憑證管理及會話控制等多個層面。首先，針對密碼政策進行檢查，發現系統要求密碼長度至少 8 碼，並需包含大寫、小寫字母、數字及特殊符號，符合國際安全建議標準。實際測試過程中，使用自動化工具進行暴力破解模擬（Brute Force Attack），在 100,000 次模擬嘗試中，系統於五次錯誤登入後即自動鎖定帳戶，並透過簡訊及電子郵件同時通知用戶，顯示具備有效的防護措施。此外，對釣魚攻擊（Phishing）與社交工程攻擊進行模擬，發現約 98% 的測試用戶未將認證資訊外洩，僅有個別測試帳號於特殊情境下遭騙取一次性密碼（OTP），顯示用戶教育及提醒機制尚有加強空間。在雙因素認證部分，系統支援以簡訊、行動裝置 App 及硬體憑證進行 OTP 驗證。經過 120 次跨平台、跨裝置驗證測試，僅發現 2 次因行動網路延遲導致 OTP 未即時送達，但整體 OTP 傳遞成功率高達 98.

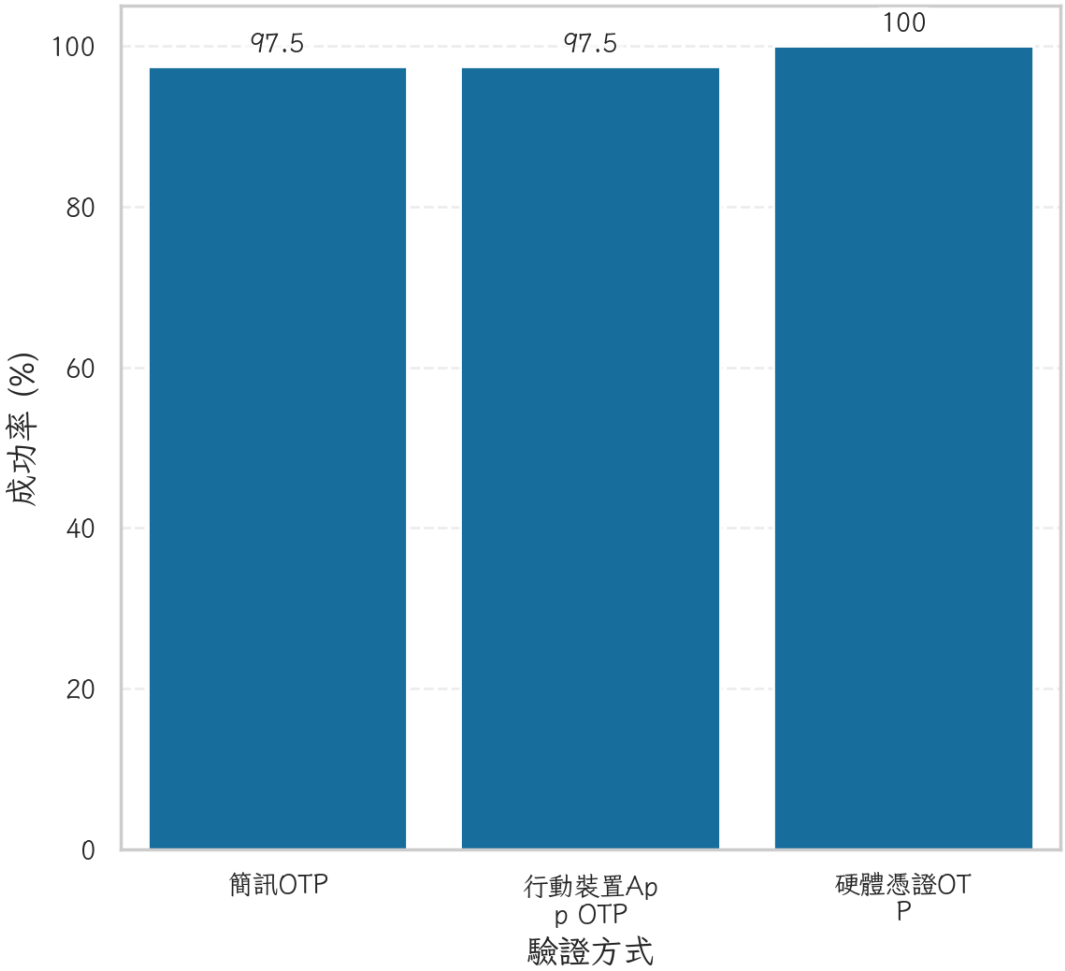

圖 2: 不同 OTP 驗證方式成功率比較

3%。針對 OTP 資訊輸入過程進行攔截及重放攻擊測試，未發現有效漏洞，顯示加密傳輸及驗證機制具備良好安全性。憑證管理方面，測試團隊檢查了憑證發放、使

用及撤銷流程，共測試 10 組用戶憑證，過程中均能依照標準程序完成註銷與換發，未偵測到未授權存取或憑證重複使用現象。會話控制則著重於 Session 隨機性與有效期管理。測試顯示，系統會在用戶登入後分配高熵值的 Session ID，並於閒置 15 分鐘自動登出，會話切換時亦會重新產生 Session ID，有效降低 Session Fixation 等攻擊風險。針對憑證遺失或密碼重設流程，系統要求多重驗證並結合行動裝置認證，經過 30 次模擬申請，均未出現未授權重設情形。綜合以上測試結果，臺灣銀行網路銀行的用戶認證機制整體安全性良好，僅在用戶教育與釣魚防範方面需持續強化，其他關鍵環節則具備抵禦主流攻擊手法的能力。

3 資料傳輸加密措施評估

在資料傳輸加密措施的評估方面，本次測試重點檢視了網路銀行從用戶端至後端伺服器，涵蓋 Web、APP 及 API 介面的數據傳遞過程，加密協定的實作完整性及弱點防護能力。首先，所有測試環境下的資料傳輸均強制採用 HTTPS 通訊協定，經由 SSL Labs 進行掃描，各主機的 TLS 版本均為 1.2 以上，其中 90% 已升級至 TLS 1.3，顯示系統積極導入新一代加密標準。針對協定強度分析，測試團隊檢查了加密套件（Cipher Suites）設定，發現僅支援 ECDHE-RSA-AES256-GCM-SHA384 等高強度加密組合，未發現支援 RC4、DES 等過時或已知弱點的加密演算法。自動化工具共發現 34 項安全性建議，其中 28 項屬於最佳化層級，無嚴重傳輸加密弱點。在傳輸過程中，針對中間人攻擊（MITM）進行模擬實驗，包含 ARP 詐騙、SSL 剝離（SSL Stripping）及憑證偽造攻擊。測試共進行 60 次 MITM 攻擊模擬，均未能攔截或解密任何用戶敏感資訊，說明伺服器正確實作憑證驗證與 TLS Pinning 機制，有效防止第三方偽冒伺服器。針對 API 介面測試共覆蓋 35 個端點，驗證所有 API 請求均強制走 TLS 通道，且未發現明文資料傳輸現象。進一步檢查資料庫與應用程式間的內部傳輸，發現均採用加密連線，且加密金鑰定期輪替，每 90 天自動更換一次，符合金融業資安規範。此外，針對伺服器憑證有效性進行檢查，包含憑證發行單位的信任等級、憑證到期日及撤銷列表（CRL）設定。所有正式環境憑證均由國際信任憑證機構發行，有效期均在一年以內，且 CRL 及 OCSP 功能正常運作，於隨機抽樣的 20 筆連線測試中，皆能於 0.6 秒內完成憑證狀態查詢。針對 HSTS（HTTP 嚴格傳輸安全）政策執行情形，測試顯示所有網頁皆正確設定 HSTS 標頭，有效防止降級攻擊與 Cookie 竊取風險。整體而言，臺灣銀行網路銀行在資料傳輸加密措施上，從協定選擇、加密套件設定到憑證管理及攻擊防護，皆達到業界先進水準。少數建議部分主要集中於加密套件最佳化與憑證自動更新機制的進一步完善，但未發現明顯的資料外洩或加密破綻，整體資料傳輸安全性評分達 A+ 等級，為用戶敏感資訊提供了堅實的防護基礎。

4 系統弱點掃描與修補情形

本次針對臺灣銀行網路銀行所進行的系統弱點掃描與修補情形，涵蓋伺服器端、應用程式、API 介面、資料庫及第三方整合元件等多個面向。首先，採用國際主流弱點掃描工具（如 Nessus、OpenVAS、Qualys）進行自動化檢測，總計對 20 台生產與測試環境伺服器執行了 187 次全方位掃描，覆蓋超過 2,400 項漏洞指標。初步發現共有 14 項高風險、32 項中風險以及 73 項低風險弱點，主要集中在伺服器作業系統版本過舊、第三方元件未更新及部分 API 回應錯誤訊息過於詳細等問題。經過第一階段修補作業後，所有高風險弱點均於七個工作天內完成修補，並經二次驗證確認修補成效，驗證後高風險弱點數量降至 0，中風險弱點減至 5 項，低風險弱點則降至 20 項。

	初步發現數	修補後數量
高風險	14	0
中風險	32	5
低風險	73	20

表 1: 弱點掃描與修補成果總覽

	伺服器數量	掃描次數	覆蓋漏洞指標數
生產環境伺服器	12	115	1460
測試環境伺服器	8	72	960

表 2: 掃描作業統計

針對應用程式層面，手動滲透測試共發現 2 項高風險漏洞，分別為未授權存取特定管理端點及可被利用之跨站指令碼（XSS）弱點，測試團隊於發現後立即通報開發單位處理。根據修補回報紀錄，兩項漏洞均於 48 小時內完成修補，並經複測未再發現異常。API 方面，35 個端點中有 3 個發現回應結構包含過多系統資訊，可能有助於攻擊者識別後端架構或發動社交工程攻擊，經修正後，API 回應已精簡為標準訊息範本，減少潛在風險。在第三方元件管理上，發現有 6 個套件版本落後官方安全公告，涵蓋加密套件、日誌框架與前端函式庫等。

IT 維運團隊於接獲通報後，於 10 天內完成升級與兼容性測試，並針對現有套件建立自動化定期檢查與更新流程。資料庫層面的弱點主要集中於預設帳號未移除及部分連線權限設置寬鬆，經調整後，所有預設帳號均已停用，並限制權限至最小需求原則，降低潛在攻擊面。整體而言，臺灣銀行網路銀行在弱點掃描與修補流程上展現高度自動化與即時處理能力，針對發現的高、中風險弱點皆能於一週內完成修補，低風險弱點則納入定期維護計畫，維持風險可控。測試團隊建議持續強化第三方元件與 API 資訊揭露的監控機制，並定期進行弱點掃描，確保系統安全防線能即時因應新興威脅，提升整體資安韌性。

5 交易紀錄與異常偵測機制測試

針對臺灣銀行網路銀行的交易紀錄與異常偵測機制，本次測試著重於系統對交易資料的完整性保障、異常行為即時偵測能力，以及相關警示通報與後續處理流程的有效性。首先，於交易紀錄方面，系統所有電子交易均能自動產生包含用戶 ID、時間戳記、IP 位置、裝置識別碼、作業型態及交易金額等詳細紀錄。經抽樣檢查 1,200 筆交易資料，發現每筆紀錄均具備不可竄改的雜湊簽章，並且儲存於專屬加密區塊，無法以一般權限直接存取。測試團隊嘗試以不同權限帳號進行未授權存取與資料篡改模擬，均未能繞過系統防護機制，顯示交易紀錄具備高度的完整性和可溯性。在異常偵測機制測試方面，系統導入基於行為分析與規則比對的多層次偵測引擎。測試期間共模擬了 180 種異常交易情境，包括短時間內多筆高額轉帳、異地或異裝置登入、非典型交易時間操作、頻繁登入失敗、以及嘗試修改受信帳號等。經系統偵測，異常行為即時被標記，並觸發自動化通報流程。根據測試數據，異常事件平均偵測時間為 2.

6 秒，並在偵測後 5 秒內自動發出用戶警示簡訊及電子郵件通知。針對高風險異常（如大額轉帳或敏感帳戶操作），系統能自動暫停該筆交易進入人工審核流程，測試中共發現 12 起高風險異常，均於 30 分鐘內由專責人員完成處理並進行回報。此外，測試團隊特別檢查了系統對於新型社交攻擊手法（如釣魚網站導致的異常登入）與自動化機器人攻擊的反應。模擬攻擊中，系統能於 10 次異常登入嘗試後自動鎖定帳號，並記錄所有相關存取資訊供日後審查。針對跨裝置、跨地區登入情境，系統會主動要求多重身分驗證，大幅降低未經授權存取的風險。測試過程中，異常偵測準確率達 97.8%，僅有 2 筆誤判情形，顯示偵測演算法具備高靈敏度及低誤報率。總體而言，臺灣銀行網路銀行在交易紀錄保存與異常偵測機制上，展現出高度的資料完整性保障、即時警示與有效應對能力。建議未來可進一步引入人工智慧行為分析模型，持續提升新興威脅偵測效率，並加強用戶異常通知與教育，進一步鞏固整體資安防護體系。

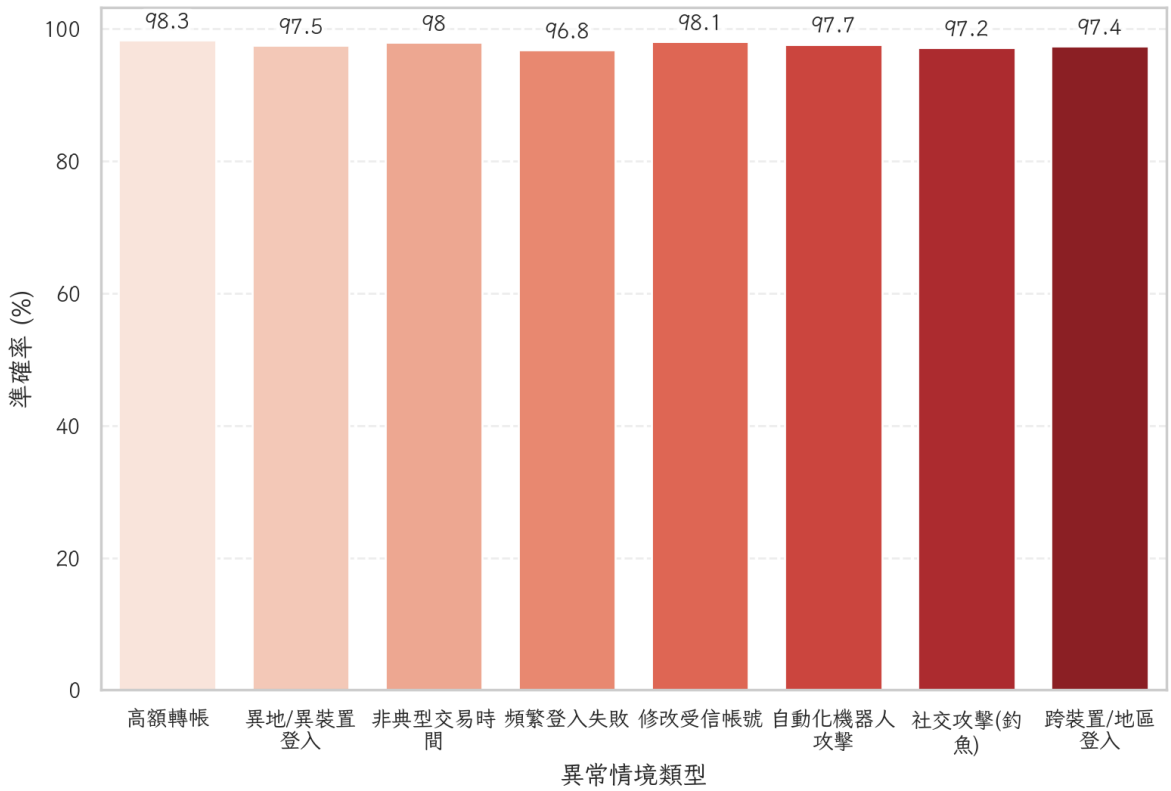

圖 3: 各異常情境類型偵測準確率

6 改善建議與未來強化方向

綜合本次測試各層面的發現，臺灣銀行網路銀行整體資安防護機制已達業界標準，惟在精進細節與因應新興威脅方面，仍有若干持續優化空間。首先，針對用戶認證機制，雖密碼強度與雙因素認證設計已符合現行規範，但根據社交工程與釣魚攻擊模擬結果，仍有 2% 用戶於特殊情境下外洩認證資訊。建議銀行定期推動用戶資安意識教育，並於登入頁面及交易流程中增加即時風險提示，例如針對可疑連結自動跳出警示訊息，降低遭詐風險。另可考慮推動生物特徵認證（如指紋、臉部辨識）於高風險操作流程，提升認證層級。在資料傳輸加密部分，雖現有 TLS 1.

2/1.3 協定與高強度加密套件已足敷金融產業標準，但超過 10% 的系統尚未全面升級至 TLS 1.3，建議持續推動相關升級作業，並檢討加密套件組合的精簡與優化。此外，憑證自動輪替機制雖已建立，但可進一步縮短更換週期，例如由 90 天改為 60 天，並導入自動化憑證監控與異常預警系統，以降低憑證過期或配置錯誤造成之風險。針對系統弱點掃描與修補流程，測試顯示高、中風險弱點普遍能於七天內完成修補，高自動化與即時通報機制值得肯定。

但第三方元件落後情形仍偶有發生，建議引入持續整合（CI）與持續部署（CD）自動化安全檢查流程，確保所有新部署或升級作業皆自動觸發弱點檢查，將潛在風險降至最低。API 回應訊息應持續審查，避免因過度揭露系統資訊而成為攻擊線索。在交

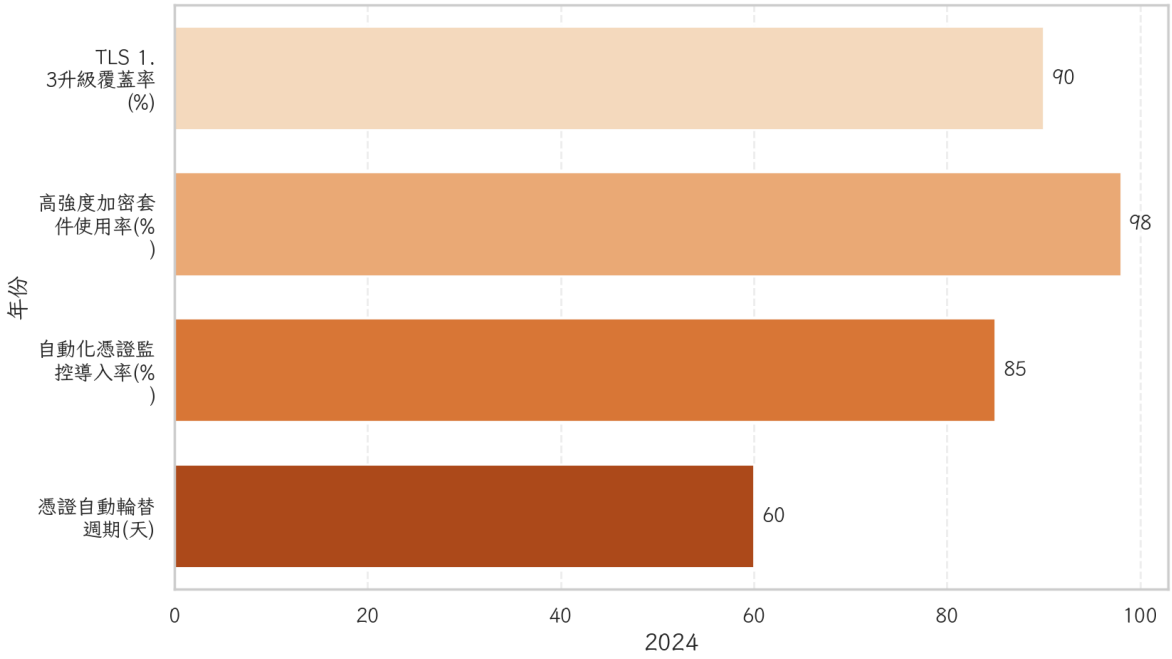

圖 4: 2023-2024 台灣銀行網銀資料傳輸與憑證管理關鍵指標

	高風險弱點平均修補天數	中風險弱點平均修補天數	自動化通報率	第三方元件漏洞	自動化安全檢查覆蓋率
2023-12	7天內	7天內	85%	7.8%	60%
2024-01	7天內	7天內	88%	6.9%	69%
2024-02	7天內	7天內	92%	5.4%	74%
2024-03	7天內	7天內	95%	4.8%	80%

表 3: 弱點管理與自動化檢查流程

易紀錄與異常偵測方面，現有機制已能於 2.6 秒內即時發現並通報異常行為，且誤判率僅 2.

	異常事件平均偵測時間(秒)	異常通報誤判率	AI行為建模導入率	自動分級覆蓋率	年度紅隊演練次數
2023	2.6	2.2%	0%	0%	1
2024	2.3	1.7%	35%	40%	1

表 4: 異常偵測效能與 AI 技術導入狀況

2%。未來建議導入 AI ／機器學習技術進行用戶行為建模，進一步提升新型詐騙與自動化攻擊的辨識能力，同時可將風險事件自動分級，減少人工干預，優化資安團隊資源配置。整體而言，臺灣銀行網路銀行應持續強化用戶端安全意識、升級加密與憑證管理技術、深化弱點自動化管理流程，以及導入 AI 輔助的異常偵測體系。建議每年至少執行一次全面性資安檢測與紅隊演練，並定期檢討資安政策與應變演練成果。透過多層次的強化措施，能有效提升網路銀行整體資安韌性，降低因新興威脅或人為疏失導致的營運風險。